

# Security & Privacy Requirements Report: StudyConnect

---

## Sicherheitskritisches Feature

Wir bewerten die Anzeige der Aufgabenübersicht ([User Story 3](#)) als das wichtigste sicherheitskritische Feature. Da die Anwendung private Informationen speichert, muss sie diese Daten vor unbefugtem Zugriff schützen. Deshalb hat die Umsetzung dieses Features Priorität und muss die Anforderungen aus SEC-REQ-01 erfüllen.

## 1. Testable Security Requirements (derived from CIA)

Basierend auf den Prinzipien der Vertraulichkeit (Confidentiality), Integrität (Integrity) und Verfügbarkeit (Availability) wurden folgende 9 testbare Sicherheitsanforderungen für die StudyConnect-API definiert:

### Confidentiality (Vertraulichkeit)

- **SEC-REQ-01:** Das System muss sicherstellen, dass ein Nutzer über den Endpunkt `GET /api/tasks` und `/api/tasks/user/<user_id>` nur Tasks abrufen kann, die ihm selbst gehören oder einer seiner Gruppen zugewiesen sind. (Test: HTTP GET mit fremder User-ID muss 403 Forbidden oder 404 Not Found zurückgeben).
- **SEC-REQ-02:** Das System darf keine sensiblen Credentials (wie `POSTGRES_PASSWORD` oder `KEYCLOAK_CLIENT_SECRET`) im Quellcode oder in den generierten Logs preisgeben. (Test: Automatischer GitLeaks/Trufflehog-Scan in der CI-Pipeline muss fehlerfrei durchlaufen).
- **SEC-REQ-03:** Die API muss sicherstellen, dass Gruppen-Metadaten und Mitgliederlisten (`GET /api/groups/<group_id>/members`) nur für authentifizierte Mitglieder dieser spezifischen Gruppe abrufbar sind. (Test: API-Aufruf durch Nicht-Mitglied muss mit 403 abgelehnt werden).

### Integrity (Integrität)

- **SEC-REQ-04 (Object-Level Authorization):** Das System muss bei `PUT /api/tasks/<task_id>` serverseitig prüfen, ob der aufrufende Nutzer der Eigentümer der Aufgabe ist, bevor Änderungen in der Datenbank gespeichert werden. (Test: PUT-Request mit dem Token von User A auf die Task-ID von User B).
- **SEC-REQ-05 (Mass Assignment Prevention):** Das System muss verhindern, dass geschützte Felder wie `user_id` oder `group_id` bei einem Task-Update durch den Client manipuliert (überschrieben) werden können. (Test: Senden eines Payloads mit veränderter `user_id`; das Backend darf dieses Feld nicht übernehmen).
- **SEC-REQ-06 (Role-Based Access Control):** Endpunkte zur Rechteausweitung (z. B. `POST /api/groups/<group_id>/add-admin`) dürfen ausschließlich von Nutzern mit der Rolle `admin` in der jeweiligen Gruppe erfolgreich ausgeführt werden. (Test: Aufruf des Endpunkts mit dem Token eines normalen `member` muss fehlerhaft sein).

### Availability (Verfügbarkeit)

- **SEC-REQ-07 (Rate Limiting):** Das System muss Anfragen an den Registrierungs-Endpoint (**POST /api/users/register**) auf maximal 5 Anfragen pro IP-Adresse innerhalb von 10 Minuten begrenzen. (*Test: Ausführen von 6 automatisierten Requests; der 6. Request muss HTTP 429 Too Many Requests zurückgeben*).
  - **SEC-REQ-08 (Input Validation):** Die API muss die Größe der eingehenden JSON-Payloads (z.B. bei der Task-Beschreibung) auf maximal 1 MB begrenzen, um Speichererschöpfung zu verhindern. (*Test: Senden eines 5 MB großen Textes muss mit HTTP 413 Payload Too Large abgelehnt werden*).
  - **SEC-REQ-09 (Secure Defaults):** Der Flask-Server darf in der Produktionsumgebung nicht im Debug-Modus (**FLASK\_DEBUG=True**) laufen, um das Starten der interaktiven Werkzeug-Konsole zu verhindern. (*Test: Abfragen von Umgebungsvariablen im Docker-Container der Prod-Umgebung*).
- 

## 2. Misuse Cases & Counter-Requirements

Hier sind drei "Misuse Cases" (Missbrauchsszenarien), die spezifische Schwachstellen von StudyConnect adressieren:

### Misuse Case 1: Unauthorized Task Manipulation (IDOR)

- **Actor:** Böswilliger Student
- **Action:** Der Angreifer loggt sich ein, erhält ein gültiges Token und sendet automatisierte **PUT /api/tasks/{id}** Requests, wobei er die **{id}** einfach hochzählt (1, 2, 3...). Ziel ist es, die Aufgaben fremder Lerngruppen zu verändern oder als erledigt zu markieren, um deren Workflow zu stören.
- **Counter-Requirement (SEC-REQ-10):** Die Service-Logik (**update\_task\_service**) muss zwingend abfragen, ob die ID des bearbeitenden Nutzers mit der **user\_id** der Aufgabe übereinstimmt oder Admin-Rechte vorliegen, bevor die Datenbank-Transaktion ausgeführt wird.

### Misuse Case 2: Covert Group Entry (Invite Bypass)

- **Actor:** Neugieriger / Spionierender Nutzer
- **Action:** Der Angreifer möchte private Lösungen und Chats einer anderen Lerngruppe lesen. Er sendet einen **POST /api/groups/join** Request und rät die **group\_id** (z.B. 4). Da die API derzeit keinen Invite-Code verlangt, tritt er der Gruppe heimlich bei.
- **Counter-Requirement (SEC-REQ-11):** Die API muss beim Beitreten in eine Gruppe neben der **group\_id** zwingend den kryptografischen **invite\_link** (Einladungscode) als Validierungsparameter fordern und prüfen.

### Misuse Case 3: Registration Flooding (DoS)

- **Actor:** Botnet / Script Kiddie
  - **Action:** Ein Angreifer schreibt ein kurzes Skript, das in Endlosschleife **POST /api/users/register** aufruft. Da weder Captchas noch Rate-Limits vorhanden sind, läuft die PostgreSQL-Datenbank und der Keycloak-Server voll mit tausenden Fake-Accounts, bis die Server abstürzen.
  - **Counter-Requirement (SEC-REQ-12):** Die Anwendung muss Rate-Limiting auf Netzwerkebene (API-Gateway oder Nginx) implementieren sowie eine Bot-Erkennung (z.B. Captcha) im React-Frontend für die Registrierung erzwingen.
- 

## 3. Privacy Requirements (Datenschutzanforderungen)

Da StudyConnect personenbezogene Daten von Studenten verarbeitet (Name, E-Mail, Fakultät, Geburtstag), müssen DSGVO-Vorgaben eingehalten werden:

- **PRIV-REQ-01 (Data Minimization & Purpose Limitation):** Das System darf ausschließlich Daten erheben, die für den Betrieb der Lernplattform zwingend notwendig sind. Sensible personenbezogene Daten (wie Noten, Gesundheitsdaten oder Religion) dürfen weder abgefragt noch in Freitextfeldern systemseitig gefördert werden.
- **PRIV-REQ-02 (Right to be Forgotten / Deletion):** Das System muss einen Endpunkt (z.B. **DELETE /api/users/me**) bereitstellen, der es einem Nutzer ermöglicht, seinen Account vollständig zu löschen. Dabei müssen seine persönlichen Tasks restlos entfernt und seine Beiträge in Gruppen (falls notwendig) anonymisiert werden.

## 4. Traceability Matrix

Diese Matrix verknüpft die Anforderungen mit den primären CIA-Schutzzielen (Confidentiality, Integrity, Availability) und den Eigenschaften des europäischen Cyber Resilience Acts (CRA).

| REQ-ID     | REQ-Description<br>(Kurzbeschreibung)     | REQ Source      | REQ-Type    | CIA Objective   | CRA Property           |
|------------|-------------------------------------------|-----------------|-------------|-----------------|------------------------|
| SEC-REQ-01 | Einschränkung von Task-Lesezugriffen      | Threat Modeling | Security    | Confidentiality | Secure by Default      |
| SEC-REQ-02 | Keine Credentials im Code/Logs            | SAST Analysis   | Security    | Confidentiality | Secure by Design       |
| SEC-REQ-03 | Isolierung von Gruppen-Metadaten          | Threat Modeling | Security    | Confidentiality | Secure by Default      |
| SEC-REQ-04 | Object-Level Auth bei Task-Updates        | Code Review     | Security    | Integrity       | Secure by Design       |
| SEC-REQ-05 | Schutz vor Mass Assignment                | Code Review     | Security    | Integrity       | Secure by Design       |
| SEC-REQ-06 | Role-Based Access Control für Admins      | Architecture    | Security    | Integrity       | Secure by Design       |
| SEC-REQ-07 | Rate Limiting bei der Registrierung       | Threat Modeling | Security    | Availability    | Protection against DoS |
| SEC-REQ-08 | Input Size Validation (Payload Limit)     | Threat Modeling | Security    | Availability    | Protection against DoS |
| SEC-REQ-09 | Deaktivierter Debug-Modus in Prod.        | SonarQube Scan  | Security    | Confidentiality | Secure by Default      |
| SEC-REQ-10 | Counter-Req: Unauthorized Task Mod        | Misuse Case 1   | Counter-Req | Integrity       | Secure by Design       |
| SEC-REQ-11 | Counter-Req: Validierung des Invite-Codes | Misuse Case 2   | Counter-Req | Confidentiality | Secure by Design       |

| REQ-ID             | REQ-Description<br>(Kurzbeschreibung)   | REQ Source    | REQ-Type    | CIA Objective     | CRA Property           |
|--------------------|-----------------------------------------|---------------|-------------|-------------------|------------------------|
| <b>SEC-REQ-12</b>  | Counter-Req: Anti-Bot bei Registrierung | Misuse Case 3 | Counter-Req | Availability      | Protection against DoS |
| <b>PRIV-REQ-01</b> | Datensparsamkeit (Data Minimization)    | DSGVO / GDPR  | Privacy     | Confidentiality   | Data Minimization      |
| <b>PRIV-REQ-02</b> | Recht auf Löschung (Account Deletion)   | DSGVO / GDPR  | Privacy     | Integrity / Conf. | Data Minimization      |